

ISOReady - ISO 27001 Implementation Methodology

Makya A*****, Dalten B*****, Brandon Stewart, Zachary T*****

PART A - Control Entry [A.X.XX - Control Name]

1: TIER ASSIGNMENT

Assigned Tier: Tier 1 - Critical / Tier 2 - Important / Tier 3 - Scoped/Inherited

Tier Rationale: [Enter rationale]

2: APPLICABILITY DECISION

Decision: Applicable / Partially Applicable / Not Applicable (Justified)

Justification: [Enter justification]

3: EXPLANATION

[Write full explanation here. Depth should match tier: Tier 1: full implementation + rationale Tier 2: high-level summary Tier 3: scope exclusion justification only]

4: CLAUSE RELEVANCE (ISO 27001:2022 Clauses 4–10)

Clause | Relevance [X.X] | [Describe how this control supports the clause] [X.X] | [Describe how this control supports the clause] [X.X] | [Describe how this control supports the clause]

5: EVIDENCE EXPECTATION

[List the artifacts an auditor would expect to see. Be specific - policy name, log type, review record format, etc.]

- [artifact]
 - [artifact]
 - [artifact]
-
-

PART B - Methodology Companion [A.X.XX - Control Name]

1: WHAT THIS CONTROL ACTUALLY REQUIRES

[Describe in plain language what ISO 27001:2022 requires for this control - what must be in place, documented, or demonstrated. Do not copy the standard verbatim; interpret it operationally.]

2: HOW TO MAKE THE TIER & APPLICABILITY DECISION

Step 1 - Assess Audit Failure Risk

Ask: if this control was missing or poorly implemented, how likely is it to generate a finding in an ISO 27001 audit?

- **HIGH** - commonly cited in real-world ISO nonconformities; auditors will actively test this
- **MEDIUM** - situationally flagged depending on the organization's sector or architecture
- **LOW** - rarely raised as a standalone finding; usually only surfaces if something else breaks first

Step 2 - Assess Control Dependencies

Ask: how many other controls depend on this one being in place to function correctly?

- **HIGH** - 5 or more controls rely on this as a prerequisite
- **MEDIUM** - 2 to 4 controls are downstream of this one
- **LOW** - this control is largely standalone with few dependencies

Step 3 - Assess Identity Relevance

Ask: does this control directly govern, restrict, or rely on identity and access management?

- **DIRECT** - the control is part of the identity and access governance stack

- **INDIRECT** - the control references or touches identity but is not primarily about it
- **NONE** - no meaningful identity dependency

Step 4 - Assess Reference Company Exposure

Ask: given the reference company's profile (cloud-first, 50–200 staff, RBAC-governed IdP, professional services), how directly does this control apply?

- **DIRECT** - fully in scope; the company owns and operates this control surface
- **PARTIAL** - applies to a subset of systems, roles, or data; some elements may be vendor-managed
- **OUT OF SCOPE** - the control does not apply to the company's architecture or service model

Step 5 - Assign the Tier

- If audit failure risk is HIGH or dependencies are HIGH → start at Tier 1
- If both are MEDIUM and identity relevance is INDIRECT or NONE → Tier 2
- If exposure is OUT OF SCOPE or the control is fully vendor-inherited → Tier 3

Step 6 - Make the Applicability Decision

- Does the control's subject matter apply to the company at all? If no → Not Applicable (Justified)
- If yes - is the company the owner of the implementation, or is it inherited from a vendor?
- If fully owned → Applicable
- If split between company and vendor → Partially Applicable
- For any Not Applicable decision: write a specific, auditable justification. Thin exclusions are a common audit finding.

When to Escalate Your Tier Assignment

If any of the following are true after you've made your initial assignment, revisit the tier before finalising:

Trigger	What to do
An auditor or senior reviewer flags the control as higher risk than your tier reflects	Reassess audit failure risk; consider moving up one tier
You discover this control is a prerequisite for more controls than you initially counted	Reassess dependencies; any Tier 3 or Tier 2 control with 3+ dependents should be reconsidered

The reference company's architecture changes (e.g. new SaaS tool, new team, restructure)	Re-run Steps 1–5 for any controls affected by the change
A vendor you relied on for a Tier 3 exclusion can no longer provide attestation	Move to Partially Applicable; reassign tier based on residual obligation
A real-world breach or incident involves this control type	Escalate to Tier 1 regardless of original score; document the reason for the change
A compliance or legal requirement is introduced that directly references this control area	Review applicability decision; Not Applicable status may no longer be defensible
During an access review or audit prep, gaps are found in the evidence for this control	Reassess whether the tier depth is sufficient; Tier 2 controls with evidence gaps should move to Tier 1

3: IMPLEMENTATION GUIDANCE (Reference Company)

Minimum required implementation:

- [step]
- [step]
- [step]

Cloud-specific notes:

- [note]
- [note]

4: CONTROL LINKAGE

Control | Relationship | Why it matters [A.X.XX] | Depends on | [explain] [A.X.XX] | Feeds into | [explain] [A.X.XX] | Related | [explain]

Relationship types:

- **Depends on** - This control requires the linked control to function correctly
- **Feeds into** - This control is a prerequisite for the linked control
- **Related** - Controls share scope or overlap but neither fully depends on the other
